

RELAZIONE LABORATORIO

Vulnerability Assessment con Nmap e Nessus

Studente	Mauro Picca
Data	07/05/2026
Corso	EPICODE — Cybersecurity & Vulnerability Assessment
Modulo	Vulnerability Assessment con Nmap e Nessus
Ambiente	Kali Linux (VirtualBox) + Metasploitable 2 + Nessus Essentials

1. Introduzione

Durante questo laboratorio è stata svolta un'attività pratica di Vulnerability Assessment utilizzando strumenti professionali di cybersecurity: Nmap e Nessus Essentials. L'esercitazione ha simulato un workflow reale comunemente utilizzato nelle fasi iniziali di un penetration test professionale.

Gli obiettivi principali dell'attività erano:

- identificare host attivi nella rete virtuale del laboratorio;
- individuare porte aperte e servizi esposti sul sistema target;
- eseguire Version Detection sui servizi rilevati;
- identificare vulnerabilità note e CVE associate mediante Nmap NSE;
- automatizzare e approfondire il Vulnerability Assessment tramite Nessus Essentials;
- valutare il livello di rischio complessivo del sistema target.

L'ambiente di laboratorio era composto da:

- Kali Linux — macchina di attacco (scanner);
- Metasploitable 2 — macchina vulnerabile target;
- Oracle VirtualBox — ambiente di virtualizzazione;
- Nessus Essentials — vulnerability scanner automatico.

Nota: Tutte le attività di scansione sono state svolte esclusivamente all'interno dell'ambiente virtuale di laboratorio controllato, su macchine di proprietà, nel rispetto del quadro legale applicabile alle attività di Vulnerability Assessment.

2. Configurazione dell'Ambiente di Laboratorio

Per l'esercitazione sono state utilizzate due macchine virtuali configurate tramite Oracle VirtualBox:

- Kali Linux — macchina di attacco con strumenti di security preinstallati;
- Metasploitable 2 — distribuzione Linux volutamente vulnerabile, progettata per attività di training.

Entrambe le VM sono state configurate con una doppia scheda di rete:

- una scheda NAT — per l'accesso Internet dalla macchina Kali;
- una scheda Host-Only — per la comunicazione interna tra le due VM.

La rete Host-Only ha permesso la comunicazione diretta all'interno della subnet virtuale 192.168.56.0/24, isolando il traffico di laboratorio dalla rete fisica.

```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 86381sec preferred_lft 86381sec
    inet6 fd17:625c:f037:2:8177:8701:44eb:6755/64 scope global dynamic noprefixroute
        valid_lft 86382sec preferred_lft 14382sec
    inet6 fe80::f22:c9d:349f:86c9/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:b0:79:70 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
        valid_lft 580sec preferred_lft 580sec
    inet6 fe80::c90:cbc2:72ee:13da/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

```

Configurazione rete Kali Linux

Descrizione: Verifica della configurazione delle interfacce di rete della macchina Kali Linux tramite il comando `ip a`. È stata identificata l'interfaccia Host-Only `eth1` con indirizzo IP `192.168.56.102/24`, utilizzata per comunicare con la macchina Metasploitable all'interno del laboratorio virtuale.

3. Host Discovery con Nmap

La prima fase del Vulnerability Assessment ha riguardato l'identificazione degli host attivi presenti nella subnet virtuale. L'host discovery è fondamentale in un VA professionale perché consente di costruire un inventario preciso dei sistemi target prima di procedere con analisi più approfondite.

Comando utilizzato:

```
nmap -sn 192.168.56.0/24
```

L'opzione `-sn` consente di effettuare una scansione di host discovery senza eseguire il port scanning, riducendo il traffico generato e aumentando la velocità della fase iniziale.

Risultati identificati:

Indirizzo IP	MAC Address (vendor)	Ruolo
192.168.56.1	VirtualBox NIC (gateway)	Gateway VirtualBox
192.168.56.101	Oracle VirtualBox	Target — Metasploitable 2
192.168.56.102	Oracle VirtualBox	Host — Kali Linux

```
(kali@kali)-[~]
$ nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 09:08 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00092s latency).
MAC Address: 0A:00:27:00:00:07 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.0010s latency).
MAC Address: 08:00:27:12:B0:0A (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up (0.0035s latency).
MAC Address: 08:00:27:73:1A:BE (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.83 seconds
```

Host Discovery della subnet 192.168.56.0/24

Descrizione: Scansione di host discovery eseguita con `nmap -sn 192.168.56.0/24` per individuare i sistemi attivi nella rete virtuale del laboratorio. La scansione ha identificato il target Metasploitable con indirizzo IP 192.168.56.101 e il relativo MAC Address con vendor Oracle VirtualBox.

4. Scansione Completa del Target con Nmap

Dopo aver identificato il target, è stata eseguita una scansione avanzata per raccogliere informazioni dettagliate su porte aperte, servizi attivi, versioni software e sistema operativo.

Comando utilizzato:

```
sudo nmap -sS -sV -O -T4 192.168.56.101 -oA full_scan
```

Opzioni utilizzate:

Opzione	Descrizione
<code>-sS</code>	SYN Scan (stealth scan): invia pacchetti SYN senza completare il 3-way handshake, riducendo le tracce nei log
<code>-sV</code>	Version Detection: identifica il software e la versione esatta in ascolto su ogni porta aperta
<code>-O</code>	OS Detection (OS Fingerprinting): stima il sistema operativo analizzando le caratteristiche dello stack TCP/IP
<code>-T4</code>	Timing template Aggressive: aumenta la velocità di scansione, ottimale per reti LAN locali
<code>-oA</code>	Output All: salva i risultati in tutti i formati disponibili (.nmap, .xml, .gnmap)

La scansione ha identificato numerose porte aperte con servizi obsoleti altamente vulnerabili:

Porta / Protocollo	Servizio	Versione identificata
21/tcp	FTP	vsFTPD 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
80/tcp	HTTP	Apache httpd 2.2.8
139 / 445/tcp	SMB	Samba smbd 3.x - 4.x
3306/tcp	MySQL	MySQL 5.0.51a
5432/tcp	PostgreSQL	PostgreSQL 8.3.0 - 8.3.7
5900/tcp	VNC	VNC Protocol 3.3
8180/tcp	HTTP (Tomcat)	Apache Tomcat

```
(kali@kali)-[~]
└─$ sudo nmap -ss -sV -O -T4 192.168.56.101 -oA full_scan
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 09:10 -0400
Nmap scan report for 192.168.56.101
Host is up (0.0026s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          Netkit rshd
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:73:1A:BE (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.87 seconds
```

Scansione completa del target con Nmap

Descrizione: Scansione avanzata del target 192.168.56.101 tramite Nmap con SYN Scan, Version Detection e OS Detection. L'analisi ha identificato numerose porte aperte, servizi attivi e versioni software obsolete potenzialmente vulnerabili. Il sistema operativo rilevato è Linux 2.6.x.

5. Salvataggio dei Risultati della Scansione

I risultati della scansione sono stati salvati automaticamente tramite l'opzione `-oA full_scan`, che genera simultaneamente i file di output in tutti i formati disponibili:

Formato	File generato	Utilizzo
.nmap	<code>full_scan.nmap</code>	Output leggibile — consultazione manuale e documentazione
.xml	<code>full_scan.xml</code>	Formato strutturato — import in Nessus, Metasploit, report HTML
.gnmap	<code>full_scan.gnmap</code>	Formato grepable — parsing automatico con grep/awk

Pro tip: Il formato `.xml` può essere convertito in un report HTML leggibile tramite il comando: `xsltproc full_scan.xml -o full_scan.html`

```
firma.py          README.md
full_scan.gnmap   s2l5.py
full_scan.nmap    somma1.py
full_scan.xml     static
gameshell        stringa2.py
```

File di output generati da Nmap

Descrizione: Verifica della generazione automatica dei file di output della scansione Nmap tramite l'opzione `-oA`. Sono stati creati i file `full_scan.nmap`, `full_scan.xml` e `full_scan.gnmap` contenenti i risultati completi dell'analisi del target.

6. Vulnerability Scan con Nmap NSE

Successivamente è stata eseguita una scansione di vulnerabilità tramite NSE (Nmap Scripting Engine), il motore di scripting integrato in Nmap che permette di estendere le capacità dello strumento attraverso script Lua.

Comando utilizzato:

```
nmap --script vuln -sV 192.168.56.101 -oA vuln_scan
```

La categoria di script `vuln` esegue automaticamente tutti gli script NSE classificati come test di vulnerabilità, consentendo di:

- identificare CVE note associate ai servizi rilevati;
- verificare la presenza di exploit pubblicamente disponibili;
- rilevare configurazioni insicure e backdoor note;
- ottenere informazioni actionable per le fasi successive del penetration test.

6.1 Vulnerabilità Critica vsFTPD 2.3.4

CVE-2011-2523 [Critical]

Backdoor nel servizio vsFTPD versione 2.3.4. Permette l'esecuzione remota di comandi con privilegi root tramite una backdoor introdotta nel codice sorgente del software tra il 30 giugno e il 2 luglio 2011.

La scansione NSE ha identificato una backdoor critica sul servizio FTP. Nmap ha verificato con successo l'esecuzione remota del comando id, ottenendo:

```
uid=0 (root)
```

Questo dimostra la possibilità di ottenere una shell remota con privilegi root completi sul sistema target, rappresentando la vulnerabilità più grave dell'intera analisi.

```
(kali@kali)-[~]
$ nmap --script vuln -sV 192.168.56.101 -oA vuln_scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 09:15 -0400
Nmap scan report for 192.168.56.101
Host is up (0.00057s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2011-2523 BID:48539
|         vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
```

Vulnerabilità critica vsFTPD 2.3.4 (CVE-2011-2523)

Descrizione: Tramite Nmap NSE è stata identificata e verificata la backdoor CVE-2011-2523 sul servizio FTP vsFTPD 2.3.4. Lo script ha confermato l'eseguibilità remota del comando id con privilegi root (uid=0), dimostrando la completa compromissione del sistema target tramite questo vettore.

6.2 Vulnerabilità del servizio OpenSSH 4.7p1

La scansione ha identificato numerose vulnerabilità associate al servizio OpenSSH nella versione 4.7p1, classificata come obsoleta e non più supportata dal progetto OpenSSH. Sono stati rilevati diversi CVE ad alta criticità relativi a questa versione del software.

```

2EC1F56532F *EXPLOIT*
| 322DD1ED-D331-573E-9AAC-5B6BEC2095F9 10.0 https://vulners.com/githubexploit/322DD1ED-D331-57
B6BEC2095F9 *EXPLOIT*
| 23DBF7D8-DD32-5D15-8D18-0CF069745409 10.0 https://vulners.com/githubexploit/23DBF7D8-DD32-5D
CF069745409 *EXPLOIT*
| 09B89183-FE26-5690-A12C-7BEC34B1AAE4 10.0 https://vulners.com/githubexploit/09B89183-FE26-56
BEC34B1AAE4 *EXPLOIT*
| 1337DAY-ID-36095 9.8 https://vulners.com/zdt/1337DAY-ID-36095 *EXPLOIT*
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| vulners:
| cpe:/a:openbsd:openssh:4.7p1:
| DF059135-2CF5-5441-8F22-E6EF1DEE5F6E 10.0 https://vulners.com/gitee/DF059135-2CF5-5441-8F22-
F6E *EXPLOIT*
| PACKETSTORM:173661 9.8 https://vulners.com/packetstorm/PACKETSTORM:173661 *EXPLOIT*

```

Vulnerabilità del servizio OpenSSH 4.7p1

Descrizione: L'analisi automatizzata tramite Nmap NSE ha identificato numerose vulnerabilità associate al servizio OpenSSH 4.7p1. Sono stati rilevati diversi exploit pubblici e CVE ad alta criticità relativi a questa versione obsoleta del servizio SSH.

6.3 Vulnerabilità Apache HTTP Server — Slowloris DoS

CVE-2007-6750 [Medium]

Slowloris Denial of Service: il servizio Apache HTTP Server 2.2.8 risulta vulnerabile all'attacco Slowloris, che permette a un attaccante di saturare il numero massimo di connessioni consentite dal server mantenendo aperte connessioni HTTP parziali.

La scansione NSE ha identificato la vulnerabilità Slowloris sul servizio Apache HTTP Server 2.2.8. Questo attacco consente a un singolo host di rendere il servizio web irraggiungibile per altri utenti, saturando le connessioni disponibili senza richiedere una larghezza di banda elevata.

```

| SSV:14986 2.6 https://vulners.com/seebug/SSV:14986 *EXPLOIT*
| CVE-2009-4022 2.6 https://vulners.com/cve/CVE-2009-4022
| PACKETSTORM:142800 0.0 https://vulners.com/packetstorm/PACKETSTORM:142800 *EXPLOIT*
| 1337DAY-ID-27896 0.0 https://vulners.com/zdt/1337DAY-ID-27896 *EXPLOIT*
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
| http-slowloris-check:
| VULNERABLE:
| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDs: CVE:CVE-2007-6750
| Slowloris tries to keep many connections to the target web server open and hold
| them open as long as possible. It accomplishes this by opening connections to
| the target web server and sending a partial request. By doing so, it starves
| the http server's resources causing Denial Of Service.

```

Vulnerabilità Apache HTTP Server (Slowloris DoS)

Descrizione: L'analisi NSE ha identificato la vulnerabilità Slowloris (CVE-2007-6750) sul servizio Apache HTTP Server 2.2.8. L'attacco consente di saturare le connessioni del web server causando Denial of Service tramite connessioni HTTP parziali mantenute aperte.

7. Vulnerability Assessment con Nessus Essentials

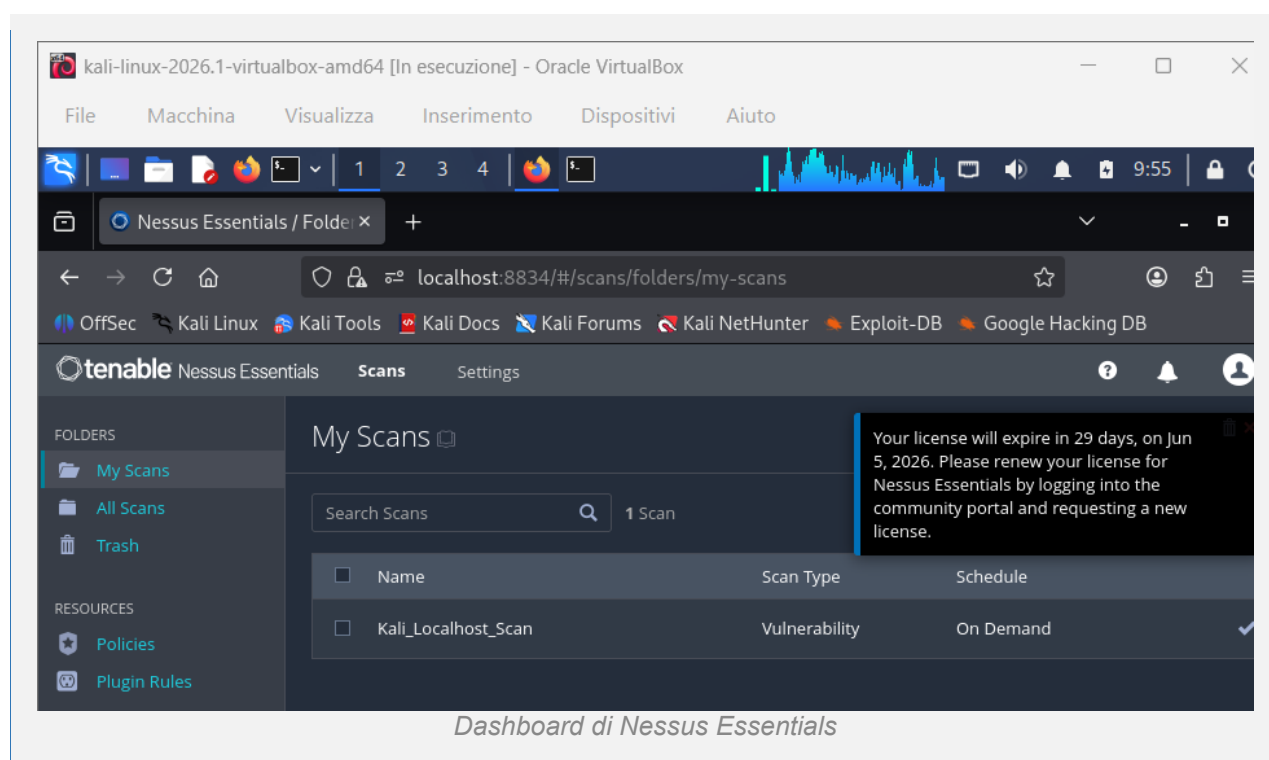
Come seconda fase dell'esercitazione è stato utilizzato Nessus Essentials per automatizzare e approfondire il processo di Vulnerability Assessment. Nessus è uno dei principali vulnerability scanner professionali del settore cybersecurity, sviluppato da Tenable Inc.

Rispetto alla scansione Nmap con NSE, Nessus offre vantaggi significativi:

- database integrato con oltre 200.000 plugin di vulnerabilità aggiornati quotidianamente;
- correlazione automatica con CVE, CVSS score e severity rating;
- suggerimenti di remediation per ogni vulnerabilità identificata;
- interfaccia web professionale con dashboard e report strutturati;
- scansioni autenticate tramite SSH, SMB o WMI per un'analisi più approfondita.

7.1 Dashboard Nessus Essentials

È stata verificata la corretta operatività di Nessus tramite l'interfaccia web locale accessibile all'indirizzo <https://localhost:8834>.



Descrizione: Accesso alla dashboard di Nessus Essentials tramite interfaccia web locale <https://localhost:8834>. Il vulnerability scanner risulta correttamente operativo e pronto per la configurazione delle scansioni di sicurezza.

7.2 Configurazione della Scansione Nessus

È stata creata una nuova scansione di tipo Basic Network Scan, il template standard per un Vulnerability Assessment completo di rete. La scansione è stata configurata con i seguenti parametri:

- Template: Basic Network Scan;
- Target: 192.168.56.101 (Metasploitable 2);
- Discovery: Port scan (common ports) con ping ICMP, TCP e ARP;
- Assessment: Default (scan for known vulnerabilities).

Metasploitable_VA / Configuration

[Back to Scan Report](#)

Settings | Credentials | Plugins

BASIC

- General
- Schedule
- Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name: Metasploitable_VA

Description: Vulnerability Assessment eseguito su Metasploitable 2 tramite Nessus Essentials.

Folder: My Scans

Targets: 192.168.56.101

Upload Targets [Add File](#)

Save Cancel

Configurazione della scansione Nessus

Descrizione: Configurazione della scansione Basic Network Scan tramite Nessus Essentials verso il target 192.168.56.101 (Metasploitable 2). La scansione è stata configurata con le impostazioni standard per un Vulnerability Assessment completo.

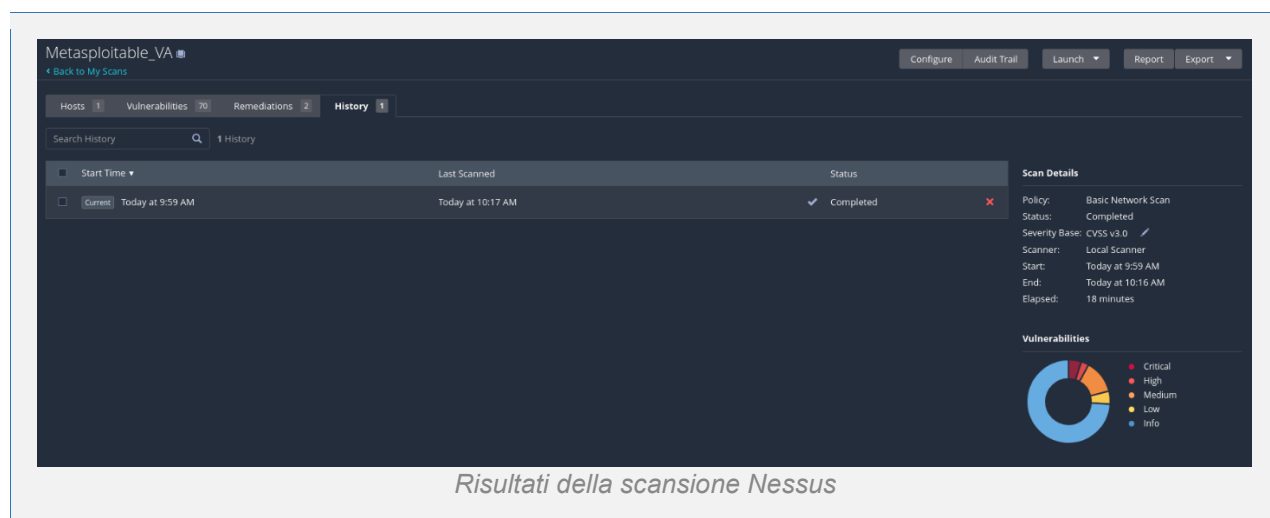
7.3 Risultati della Scansione Nessus

Al termine della scansione, Nessus ha identificato un totale di 70 vulnerabilità, suddivise per livello di gravità secondo la scala standard CVSS:

Critical	High	Medium	Low/Info
5+	8+	10+	47+

Principali vulnerabilità identificate:

Vulnerabilità	Gravità	Porta
Bind Shell Backdoor Detection	Critical	1524/tcp
VNC Server 'password' Password	Critical	5900/tcp
SSL Version 2 and 3 Detection	Critical	443/tcp
Samba Badlock Vulnerability	High	445/tcp
rlogin Service Detection	High	513/tcp
Unencrypted Telnet Server	Medium	23/tcp
TLS Version 1.0 Protocol Detection	Medium	443/tcp
SMB Signing not required	Medium	445/tcp



Descrizione: Panoramica dei risultati della scansione Nessus Essentials sul target Metasploitable. La scansione ha identificato 70 vulnerabilità totali suddivise per livello di gravità CVSS, con diverse vulnerabilità critiche e ad alta priorità.

CVSS	WPN	EPDS	Name	Family	Count
10.0	...	...	Canonical Ubuntu Linux Shell (RHEL)	General	1
10.0	...	...	VNC Server (password) Password	Gain a shell remotely	1
9.8	...	...	Bind Shell Backdoor Detection	Service detection	2
9.8	...	...	Bind Shell Backdoor Detection	Backdoors	1
...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
7.5	6.7	0.5005	rsync Service Detection	Service detection	1
7.5	5.9	0.7852	Samba Backdoor Vulnerability	General	1
7.5	...	...	NFS Shares World Readable	RPC	1
...	...	...	SSL (Multiple Issues)	General	28
...	...	...	ISC Bind (Multiple Issues)	DNS	5
6.5	...	...	TLS Version 1.0 Protocol Detection	Service detection	2
6.5	...	...	Unencrypted Telnet Server	Misc.	1
5.9	4.8	0.027	SSL Anonymous Cipher Suites Supported	Service detection	1
5.9	3.6	0.9035	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened effortless)	Misc.	1
...	...	...	SSH (Multiple Issues)	Misc.	6
...	...	...	HTTP (Multiple Issues)	Web Servers	5
...	...	...	SMB (Multiple Issues)	Misc.	2
...	...	...	TLS (Multiple Issues)	Misc.	2
...	...	...	TLS (Multiple Issues)	SMTP problems	2
3.7	2.9	0.9374	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Legacy)	Misc.	1

Vulnerabilità identificate da Nessus Essentials

Descrizione: Vista dettagliata delle vulnerabilità identificate da Nessus Essentials, organizzate per severity score. In evidenza le vulnerabilità Critical con punteggio CVSS 10.0 e 9.8, tra cui la Bind Shell Backdoor e la VNC Weak Password.

7.4 Vulnerabilità Critica: Bind Shell Backdoor

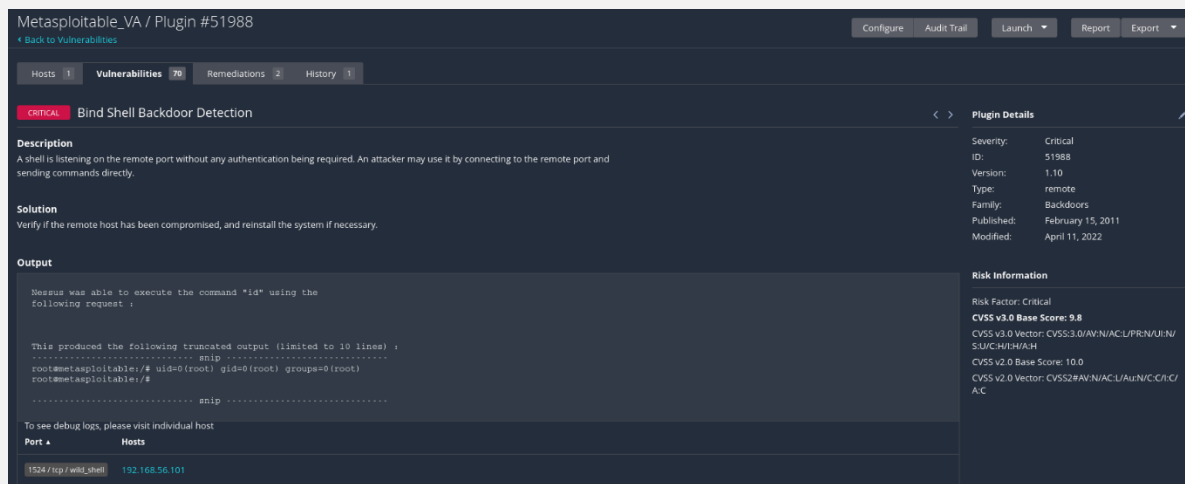
Bind Shell Backdoor Detection [Critical]

CVSS 9.8 — Porta 1524/tcp. Presenza di una shell remota accessibile senza autenticazione. Il plugin Nessus ha verificato con successo l'esecuzione remota del comando id, ottenendo uid=0(root).

Nessus ha identificato e verificato la presenza di una Bind Shell Backdoor attiva sulla porta 1524/tcp. L'accesso alla shell non richiede alcuna autenticazione: il plugin Nessus ha ottenuto direttamente privilegi root sul sistema.

Output del plugin:

```
Port 1524/tcp — Bind Shell Backdoor
uid=0(root) gid=0(root) groups=0(root)
State: VULNERABLE — Exploitable
```



Dettaglio vulnerabilità critica Bind Shell Backdoor

Descrizione: Nessus Essentials ha identificato e verificato la vulnerabilità critica Bind Shell Backdoor sulla porta 1524/tcp. Il plugin ha confermato l'esecuzione remota del comando id con risultato uid=0(root), dimostrando l'accesso root immediato al sistema senza necessità di autenticazione. CVSS Score: 9.8.

7.5 Vulnerabilità Critica: VNC Server Weak Password

VNC Server 'password' Password [Critical]

CVSS 10.0 — Porta 5900/tcp. Il servizio VNC utilizza la password predefinita 'password'. Nessus ha verificato con successo l'autenticazione tramite questa credenziale, consentendo accesso grafico remoto al sistema.

La scansione Nessus ha identificato una vulnerabilità critica sul servizio VNC esposto sulla porta 5900/tcp. Il vulnerability scanner ha verificato automaticamente la presenza di credenziali deboli, riuscendo ad autenticarsi con la password:

```
password
```

Questa vulnerabilità permette a qualsiasi attaccante raggiungibile in rete di ottenere il controllo grafico completo del sistema target tramite desktop remoto VNC, senza necessità di competenze tecniche specifiche.

Metasploitable_VA / Plugin #61708

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 70 Remediations 2 History 1

CRITICAL VNC Server 'password' Password

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution
Secure the VNC service with a strong password.

Output
Nessus logged in using a password of "password".
To see debug logs, please visit individual host

Port Hosts
5900 / tcp / vnc 192.168.56.101

Plugin Details

Severity: Critical
ID: 61708
Version: \$Revision: 1.2 \$
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 24, 2015

Risk Information

Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

Default Account: true
Exploited by Nessus: true

Vulnerabilità critica VNC con password debole

Descrizione: Nessus Essentials ha identificato e verificato la vulnerabilità critica sul servizio VNC (porta 5900/tcp). Il plugin ha verificato con successo l'autenticazione utilizzando la password debole 'password', confermando la possibilità di accesso grafico remoto non autorizzato al sistema target. CVSS Score: 10.0.

8. Conclusioni

Il laboratorio ha permesso di simulare un workflow realistico di Vulnerability Assessment professionale, dall'host discovery fino all'identificazione e verifica di vulnerabilità critiche. L'utilizzo combinato di Nmap e Nessus ha consentito di coprire l'intero processo in modo sistematico e documentato.

Risultati principali dell'analisi:

- Identificazione di 3 host attivi nella subnet virtuale 192.168.56.0/24;
- Rilevamento di oltre 20 porte aperte sul sistema Metasploitable con servizi attivi;
- Version Detection su tutti i servizi principali, evidenziando software obsoleti e fuori supporto;
- Identificazione e verifica di vulnerabilità critiche tramite Nmap NSE;
- Vulnerability Assessment automatizzato con Nessus: 70 vulnerabilità identificate, di cui 5+ Critical.

Vulnerabilità più critiche rilevate:

Vulnerabilità	Strumento	Gravità	Impatto
vsFTPD 2.3.4 Backdoor (CVE-2011-2523)	Nmap NSE	Critical	RCE con uid=root
Bind Shell Backdoor (porta 1524)	Nessus	Critical	Accesso root senza auth
VNC Weak Password	Nessus	Critical	Desktop remoto non auth
Apache Slowloris DoS (CVE-2007-6750)	Nmap NSE	Medium	Denial of Service
Telnet non cifrato (porta 23)	Nmap + Nessus	Medium	Traffico in chiaro

Considerazioni finali:

Il laboratorio ha evidenziato un aspetto fondamentale del Vulnerability Assessment professionale: la Version Detection è il passaggio critico che trasforma un semplice port scan in un'analisi actionable. Conoscere la versione esatta di ogni servizio consente di correlare immediatamente il software con database CVE pubblici (NVD, Exploit-DB) e identificare exploit disponibili.

L'esercitazione ha inoltre permesso di osservare concretamente la differenza tra i due approcci adottati:

- Nmap — analisi semi-manuale, flessibile, orientata al rilevamento di vulnerabilità specifiche tramite scripting NSE; particolarmente utile per target singoli e analisi approfondita;
- Nessus — vulnerability management automatizzato, con database aggiornato quotidianamente, severity scoring CVSS integrato e remediation guidance; ideale per l'analisi sistematica di reti enterprise.

Il workflow adottato durante il laboratorio rispecchia fedelmente le procedure utilizzate in ambienti professionali durante le fasi iniziali di un penetration test: dalla ricognizione passiva (OSINT) all'host discovery, dalla scansione di porte e servizi fino al Vulnerability Assessment completo con strumenti industriali.

Fine Relazione — Vulnerability Assessment con Nmap e Nessus

Mauro Picca | 07/05/2026